Fase 4 — GLPI en la nube

Diseño, configuración completa y base de conocimiento (13 artículos)

Caso	C23 — TalentoRemoto Staffing TI S.A.S. (empresa ficticia, 10 empleados, 20 equipos)
Consultor(es)	Angel David Rey
Programa / institución	Ingeniería de Sistemas — Unidades Tecnológicas de Santander
Versión / fecha	v1.0 — 22 de octubre de 2026

Documento elaborado por Angel David Rey (consultor, caso C23): diseño y contenido de GLPI listos para cargar. Todos los datos de la empresa, usuarios y direcciones son ficticios. Los pocos campos resaltados dependen de acciones que solo se pueden registrar al ejecutarlas (resultados de la prueba de restauración). Las contraseñas se manejan con el marcador CAMBIAR_CLAVE y nunca se escriben en informes, capturas o repositorio.

1. Ficha de diseño en la nube

Decisión	Definición para C23	Justificación
Modelo	GLPI autoadministrado en una VM Ubuntu Server LTS (GLP-C23).	Control total de la configuración y del endurecimiento; costo bajo frente al tope de OPEX (≤ COP 1,5 M/mes).
Proveedor y región	Amazon Web Services (EC2) · región sa-east-1 (São Paulo), la región de AWS más cercana a Colombia con servicios de cómputo estándar. Instancia t3.medium (2 vCPU, 4 GB) con volumen de 40 GB.	Criterios: latencia baja desde Colombia, instantáneas de volumen y copias, grupos de seguridad, imagen oficial de Ubuntu Server LTS y capa gratuita o créditos educativos para el ejercicio.
Tamaño	2 vCPU, 4 GB de RAM, 40 GB SSD.	Referencia de la guía para ~10 usuarios y 20 equipos con inventario; crecimiento previsto bajo (empresa de 10 empleados). Escalar si se superan 50 usuarios.
Red y seguridad	IP fija; grupo de seguridad: 443 abierto, 80 solo para validar el certificado, 22 solo desde la IP del administrador; HTTPS obligatorio.	Superficie de ataque mínima; el equipo es 100 % remoto, por eso el acceso se limita por puertos y no por red de oficina.
Dominio y certificado	Subdominio soporte.talentoremoto.example (marcador de la empresa ficticia) con certificado válido de Let's Encrypt. Como .example no es un dominio real, al desplegar se usa un subdominio propio que Angel David Rey controle (registro A hacia la IP fija).	Alternativa si no hay dominio: certificado autofirmado (el navegador muestra advertencia, sin renovación automática); documentar la limitación y no usar datos reales.
Respaldos	Copia diaria de BD y archivos (retención 14 días), copia fuera del servidor e instantánea.	Cubre pérdida del servidor y errores de configuración; prueba de restauración documentada.
Entidades y marca	Entidad raíz «TalentoRemoto Staffing TI S.A.S.» y 4 subentidades; logo ficticio propio (se entrega PNG).	Marca corporativa del caso.
Costo mensual	Se calcula con la calculadora oficial de AWS (t3.medium + 40 GB + IP elástica + instantáneas) al crear la instancia; no se inventan valores.	Se lleva al presupuesto de la Fase 7 como OPEX.

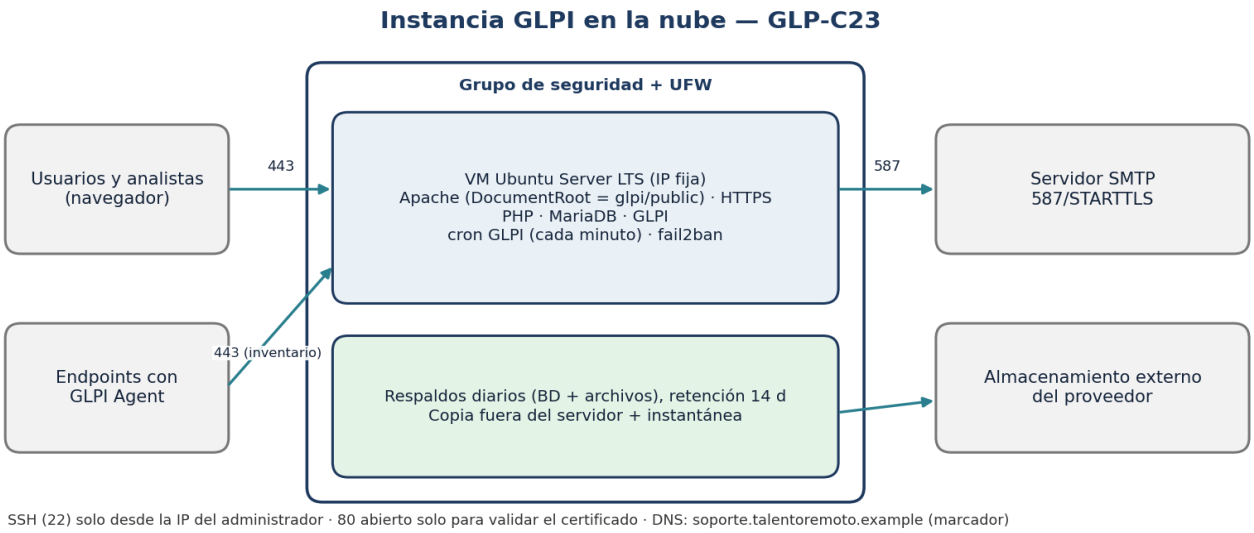


Figura 1. Diagrama simple de la instancia GLPI en la nube.

2. Instalación y endurecimiento del servidor

Versión: GLPI 11.0.x (rama estable vigente al descargar; exige PHP 8.2 y MariaDB 10.6 como mínimo; si la imagen de Ubuntu trae PHP anterior, usar la rama 10.0.x). Verificar en la documentación oficial los requisitos de la versión elegida (PHP y MariaDB mínimos) y que el DocumentRoot apunte al directorio *public*.

Paso	Acción	Evidencia
1	Crear la instancia Ubuntu Server LTS con llave SSH; IP pública fija; grupo de seguridad (443 y 80; 22 solo desde su IP); registro DNS; instantánea inicial.	F04_01_instancia, F04_02_grupo_seguridad
2	Endurecer: usuario administrador nominal (soc-admin), SSH solo por llave y sin root, UFW, fail2ban y parches automáticos. Probar el acceso por llave en una segunda sesión **antes** de desactivar la contraseña.	F04_03_ssh_firewall
3	Instalar Apache, MariaDB y PHP con las extensiones exigidas; ajustar PHP (memory_limit 256M, cookies httponly/secure/samesite); crear BD y usuario con clave fuerte (CAMBIAR_CLAVE); cargar zonas horarias.	F04_04_pila_web
4	Descargar GLPI desde la página oficial de lanzamientos; configurar el sitio de Apache con DocumentRoot en *public*; habilitar rewrite; emitir el certificado con certbot y comprobar la renovación automática.	F04_05_apache_https
5	Instalación web: idioma, licencia, datos de BD. **Cambiar de inmediato** la contraseña de la cuenta por defecto, crear la cuenta nominal de super administrador y desactivar o eliminar las cuentas glpi, tech, normal y post-only; eliminar o bloquear install/install.php si existe; revisar el diagnóstico.	F04_06_instalacion, F04_07_cuentas
6	Cron: tarea de cada minuto con www-data y modo CLI en Configurar → Acciones automáticas; verificar que las acciones se ejecutan.	F04_08_cron
7	Zona horaria America/Bogota en el servidor, en la BD y en GLPI.	F04_09_zona_horaria

Los comandos exactos están en la sección 4 de la guía del parcial (4.2 a 4.6); use siempre marcadores en lugar de claves reales cuando documente.

3. Entidades y ubicaciones

Elemento	Valor
Entidad raíz	TalentoRemoto Staffing TI S.A.S. (datos de contacto ficticios: dirección «Trabajo 100 % remoto», correo soporte@talentoremoto.example, teléfono ficticio)
Subentidades	Gerencia · Operaciones (consultores) · Soporte y Seguridad (SOC) · RR. HH.
Ubicaciones	Puestos remotos (domicilio del empleado) · Nube — servidores (VPN e identidad) · Laboratorio SOC · Nube — GLPI. (No existe sede física: se documenta la decisión.)

Elemento	Valor
Calendarios	«Horario laboral»: lunes a viernes 7:00–19:00 (America/Bogota). «24×7»: todos los días, 24 horas, para severidad crítica.

4. Perfiles, grupos y 10 usuarios ficticios

Perfil	Quién	Permisos clave
Super administrador	Responsable del SOC (E03), cuenta nominal; uso restringido	Todo, incluida la configuración global. Sin uso diario.
Administrador SOC (copia de «Admin»)	Analista N2 / responsable	Gestionar tickets, activos, categorías, SLA y reglas; sin cambios críticos del sistema.
Analista N1 (copia de «Technician»)	Analistas N1	Crear, actualizar y resolver tickets; ver activos; usar la base de conocimiento; sin borrar tickets ni modificar la configuración.
Supervisor	Gerencia	Ver tickets y reportes; validar soluciones.
Autoservicio	Empleados	Crear tickets (reportar phishing, solicitudes), ver sus tickets y la base de conocimiento pública.

Grupos: **SOC N1**, **SOC N2** y **Usuarios**. Política de contraseñas robusta (longitud mínima, complejidad, cierre de sesión por inactividad). **No registre contraseñas**: genere una temporal por usuario y fuerce el cambio en el primer inicio de sesión.

ID	Usuario (login)	Nombre ficticio	Cargo	Entidad	Perfil	Grupo	Equipo
E01	laura.mendoza	Laura Mendoza	Gerente general	Gerencia	Supervisor	Usuarios	WS-C23-01
E02	camilo.rios	Camilo Ríos	Coordinador de RR. HH.	RR. HH.	Autoservicio	Usuarios	WS-C23-02
E03	andres.salazar	Andrés Salazar	Administrador de TI / Responsable del SOC	Soporte y Seguridad	Super administrador (cuenta nominal) + Administrador SOC	SOC N2	WS-C23-01 (admin.)
E04	valentina.duarte	Valentina Duarte	Consultora TI — Analista SOC N1 (turno A)	Soporte y Seguridad	Analista N1	SOC N1	PC-C23-01
E05	sebastian.ortiz	Sebastián Ortiz	Consultor TI — Analista SOC N1 (turno B)	Soporte y Seguridad	Analista N1	SOC N1	PC-C23-02
E06	mariana.pardo	Mariana Pardo	Consultora TI — Soporte N2	Soporte y Seguridad	Administrador SOC	SOC N2	MAC-C23-01
E07	julian.cardenas	Julián Cárdenas	Consultor TI	Operaciones	Autoservicio	Usuarios	PC-C23-03
E08	daniela.quintero	Daniela Quintero	Consultora TI	Operaciones	Autoservicio	Usuarios	PC-C23-04
E09	felipe.arango	Felipe Arango	Consultor TI	Operaciones	Autoservicio	Usuarios	UBU-C23-02
E10	natalia.beltran	Natalia Beltrán	Consultora TI	Operaciones	Autoservicio	Usuarios	MAC-C23-02

Correos con el dominio reservado *talentoremoto.example* (no existe). Los analistas A y B del Manual SOC corresponden a E04 y E05; el soporte N2 interno, a E06; el responsable del SOC, a E03.

5. Categorías ITIL, prioridad y SLA/OLA

Categoría raíz	Subcategorías
Seguridad	Malware / EDR · Acceso no autorizado y autenticación · Phishing e ingeniería social · Integridad de archivos (FIM) · Dispositivos extraíbles (USB) · Reconocimiento de red (escaneo de puertos) · Cuentas y privilegios · Vulnerabilidades · Fuga de datos / exfiltración · **Control de agentes (EDR/SIEM)** (adicional C23, para PB-10)
Incidente de TI	Hardware · Software · Red
Solicitud	Alta y baja de usuarios · Instalación de software · Acceso a recursos
Cambio	Cambios de configuración de seguridad · Exclusiones del EDR · Modificación de reglas del SIEM

Matriz de prioridad. En Configurar → General → Asistencia, ajustar la matriz urgencia × impacto para que la combinación coincida con la severidad del SOC (verificar el resultado creando un ticket de prueba por severidad):

Severidad del SOC	Urgencia + impacto sugeridos	Prioridad GLPI	Reconocer (TTO)	Resolver / contener (TTR)	Calendario
Crítica	Muy alta + Muy alto	Mayor	15 min	4 h	24×7
Alta	Alta + Alto	Muy alta	30 min	8 h	24×7 con guardia
Media	Media + Medio	Media	2 h	24 h	Horario laboral
Baja	Baja + Bajo	Baja	8 h hábiles	72 h	Horario laboral
Informativa	Muy baja + Muy bajo	Muy baja	1 día hábil	5 días hábiles	Horario laboral

SLA (uno por prioridad, TTO y TTR como arriba, con su calendario) y **OLA N1 → N2:** N2 reconoce en 30 min si es crítico, 2 h si es alto y el siguiente día hábil si es medio. **Niveles de escalamiento** sugeridos: al 75 % del TTO sin reconocer, notificar al responsable del SOC; al 100 % del TTO o TTR, subir la prioridad y asignar a «SOC N2»; en crítica, notificar a gerencia. Estos tiempos son idénticos a los del Manual SOC N1 (Fase 6); si cambia uno, cambie el otro.

6. Plantilla de ticket «Alerta de seguridad»

Campo	Oblig.	Descripción / valor
Título	Sí	Formato: [Origen] [ID de alerta] – resumen corto
Tipo	Predefinido	Incidente
Categoría	Sí	Subcategoría de Seguridad (incluye «Control de agentes (EDR/SIEM)»)
Origen de la solicitud	Sí	Wazuh · Kaspersky · NGFW · Usuario
Elemento asociado	Sí	Activo afectado del inventario
Urgencia e impacto	Sí	Determinan la prioridad según la matriz
Descripción	Sí	Texto guiado (abajo)
Grupo asignado	Automático	SOC N1, por regla de negocio

```
ID de regla / alerta:
Fecha y hora (zona America/Bogota):
Activo y usuario afectados:
IP de origen / destino:
Qué ocurrió (2-3 líneas):
Evidencias (enlaces, capturas, hash):
Acciones realizadas por N1:
Decisión (falso positivo / verdadero positivo / escalar):
```

7. Reglas de negocio para tickets

#	Nombre	Criterio	Acción
R1	Asignar SOC N1 a seguridad	Categoría: es Seguridad (o cualquiera de sus subcategorías)	Asignar grupo «SOC N1»; tipo Incidente
R2	EDR malicioso	Origen = Kaspersky y categoría = Malware / EDR	Urgencia Alta
R3	Fuga de datos	Categoría = Fuga de datos / exfiltración	Urgencia Muy alta e impacto Alto (sube la prioridad)
R4	Cuentas y privilegios	Categoría = Cuentas y privilegios	Urgencia Alta
R5	Agente detenido	Categoría = Control de agentes (EDR/SIEM)	Urgencia Media; sube a Alta por el playbook PB-10 si no hay explicación
R6	Asignar SLA por prioridad	Prioridad = Mayor / Muy alta / Media / Baja / Muy baja (una regla por valor)	Asignar el SLA (TTO/TTR) y la OLA de la sección 5
R7	Phishing por correo	Receptor de correo del buzón de reporte	Categoría «Phishing e ingeniería social»; grupo SOC N1
R8	Solicitudes de usuarios	Tipo = Solicitud	Asignar grupo «SOC N2» (administración de TI)

8. Notificaciones por correo

- Habilitar seguimientos por correo y configurar SMTP: host smtp.gmail.com, puerto **587** con STARTTLS, usuario = cuenta de correo creada para el ejercicio, **contraseña de aplicación** (marcador CAMBIAR_CLAVE) y nombre de remitente «Soporte SOC N1 — TalentoRemoto» (el correo remitente será el de esa cuenta).
- Activar: ticket nuevo, ticket asignado, escalamiento por SLA, SLA próximo a vencer y ticket solucionado.
- Plantilla de correo con el nombre de la empresa y firma común: «Equipo SOC N1 — TalentoRemoto Staffing TI S.A.S.. Contacto: soporte@talentoremoto.example. Mensaje generado automáticamente.»
- Prueba de envío y captura del **mensaje recibido** (F04_12_correo_recibido). Comprobar que el cron está activo, o los correos no salen.
- Opcional: receptor de correo del buzón de reporte de phishing que crea tickets de categoría «Phishing» (regla R7).

9. Inventario de activos

- Habilitar el inventario nativo en Configurar → Inventario y Activos.
- Instalar GLPI Agent en los equipos del laboratorio (PC-C23-01 y UBU-C23-01) apuntando a la URL de inventario de la instancia (verificar la ruta y los parámetros vigentes del instalador de la versión elegida).
- Registrar manualmente: NGFW-C23 (cotizado), servicios en la nube (VPN, identidad), Microsoft 365, licencia de Kaspersky (versión de prueba) y contratos de soporte.
- Estados del ciclo de vida: en uso · en laboratorio · en reparación · retirado; vincular activos a tickets (campo «Elemento asociado»).
- **Plan para los 20 equipos reales:** GLPI Agent en todos mediante el instalador de cada sistema (MSI para Windows, instalador de Perl para Linux, paquete para macOS — verificar compatibilidad), distribuido con un script y registrado en el Anexo A; los equipos sin conexión a la VPN se inventarían al reconectarse.

10. Base de conocimiento (13 artículos)

Mínimo exigido: 12. Un artículo por playbook (10 con PB-10), el procedimiento de escalamiento con la matriz de severidad y dos guías para usuarios. Visibilidad por perfil como se indica.

KB-01 · Playbook PB-01 — Fuerza bruta SSH / RDP	**Objetivo:** Detectar y contener intentos masivos de adivinar credenciales contra el servidor VPN/gateway (SRV-C23-VPN), el servidor de identidad (SRV-C23-AD) o equipos remotos. **Cuándo usarlo:** Wazuh: múltiples fallos de autenticación (reglas sshd, p. ej. 5763, o eventos de Windows); regla personalizada 100111 si aplica; NGFW (intentos contra el puerto de la VPN). **Qué validar:** (1) ¿La IP de origen es interna (VPN) o externa? Consultar reputación en fuentes públicas. (2) ¿Cuántos intentos, contra cuántos usuarios y en qué ventana (umbral de la regla: 5 fallos en 120 s)? (3) ¿Hubo acceso exitoso con el mismo usuario o desde la misma IP? (4) ¿El servicio debe estar expuesto a Internet (solo la VPN)? (5) ¿Es una prueba autorizada del laboratorio o un usuario que olvidó su clave? **Contención permitida a N1:** Verificar que el active response (firewall-drop) bloqueó la IP o bloquearla temporalmente en el NGFW. Solicitar a TI el bloqueo de la cuenta objetivo si no es privilegiada y hay riesgo. No reiniciar servicios. **No debe realizar:** Reiniciar o detener SRV-C23-VPN; borrar logs; bloquear cuentas privilegiadas; contraatacar la IP de origen. **Escalar si:** Acceso exitoso tras los fallos; cuenta privilegiada; IP interna; objetivo en servidor crítico. **Cierre en GLPI:** Ticket con plantilla «Alerta de seguridad», clasificación y solución; adjuntar evidencias; recomendar MFA y restringir la exposición del servicio. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-02 · Playbook PB-02 — Malware / infostealer detectado por el EDR	**Objetivo:** Gestionar detecciones de Kaspersky (incluido el ladrón de credenciales bloqueado, escenario 2 de C23) en portátiles remotos y servidores. **Cuándo usarlo:** Kaspersky: detección de objeto malicioso (p. ej. Trojan-PSW / infostealer); alerta en Wazuh con la regla 100310 (decoder CEF de Kaspersky). **Qué validar:** (1) ¿Qué acción tomó el EDR: bloqueó, desinfectó, cuarentena o se ejecutó? (2) Nombre de la amenaza, ruta, hash, proceso padre y usuario. (3) ¿Otros equipos tienen el mismo hash? (4) ¿Origen probable (correo, USB, web, descarga)? (5) Consultar la reputación del hash sin subir el archivo. (6) Por ser un infostealer: ¿qué credenciales o sesiones pudieron exponerse (navegador, M365, VPN, accesos de clientes)? **Contención permitida a N1:** Poner el archivo en cuarentena; aislar el equipo desde la consola si el malware se ejecutó o hay propagación; informar al usuario por canal alterno; solicitar a TI cierre de sesiones y cambio de contraseñas de la cuenta (no privilegiada) del usuario. No apagar el equipo salvo instrucción de N2. **No debe realizar:** Borrar el archivo manualmente, reinstalar el equipo, ingeniería inversa de la muestra, cambiar contraseñas de cuentas privilegiadas. **Escalar si:** Ejecución confirmada, indicios de uso de credenciales, más de un equipo, servidor afectado o EDR sin poder remediar. **Cierre en GLPI:** Confirmar limpieza con análisis completo; registrar causa probable; capacitar al usuario; notificar al responsable del SOC si hay credenciales de clientes en riesgo. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-03 · Playbook PB-03 — Cambio en archivos críticos (FIM)	**Objetivo:** Validar cambios en rutas vigiladas por Wazuh (configuración de la VPN, archivos de cuentas y privilegios, binarios, carpetas de RR. HH.). **Cuándo usarlo:** Wazuh: reglas de syscheck (archivo agregado, modificado o eliminado) en rutas vigiladas definidas en agent.conf. **Qué validar:** (1) ¿Existe un ticket de cambio aprobado en GLPI para esa ventana? (2) ¿Qué usuario o proceso realizó el cambio? (3) ¿Qué cambió (hash, permisos, contenido)? (4) ¿Coincide con una actualización o despliegue? (5) ¿Es un ejecutable nuevo en un directorio sensible? **Contención permitida a N1:** No modificar ni borrar el archivo. Si hay indicios de compromiso, escalar y solicitar a N2 el aislamiento. **No debe realizar:** Revertir el cambio por cuenta propia, borrar el archivo, desactivar syscheck. **Escalar si:** Sin ticket de cambio en servidor crítico; cambios en binarios, autenticación o tareas programadas; cambios en configuración del agente de seguridad. **Cierre en GLPI:** Si es legítimo, vincular al ticket de cambio y cerrar como benigno; si no, escalar. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-04 · Playbook PB-04 — Inicio de sesión anómalo (país inusual / fuera de horario)	**Objetivo:** Atender accesos a la VPN o a sistemas desde ubicaciones o IP no esperadas o fuera de horario (escenario 1 de C23). **Cuándo usarlo:** Regla personalizada 100300 (inicio de sesión exitoso desde IP fuera de la lista autorizada, usada como proxy de «país sin personal») y 100100 (fuera de horario); NGFW: acceso a la VPN desde un país sin personal. **Qué validar:** (1) ¿El usuario tenía trabajo remoto o viaje autorizado (calendario o ticket)? (2) ¿La IP y la ubicación (GeoIP en el tablero) son habituales? (3) ¿Hay dos accesos desde ubicaciones lejanas en poco tiempo? (4) ¿Qué hizo tras el acceso (descargas, cambios, nuevas cuentas)? (5) Confirmar con el usuario por un canal alterno (llamada), sin enviar datos sensibles. **Contención permitida a N1:** Si no es legítimo: solicitar el cierre de sesiones y el restablecimiento de contraseña; solicitar a TI el bloqueo de la cuenta si no es privilegiada; bloquear temporalmente la IP en el NGFW. **No debe realizar:** Eliminar o modificar cuentas, acceder al equipo del usuario, probar la contraseña del usuario. **Escalar si:** Cuenta privilegiada; acciones sensibles posteriores; el usuario no reconoce el acceso; varias cuentas implicadas. **Cierre en GLPI:** Documentar la excepción autorizada (viaje) o el incidente; recomendar MFA y restricciones por geografía. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-05 · Playbook PB-05 — Uso de USB no autorizado	**Objetivo:** Controlar el uso de dispositivos externos en portátiles remotos, donde hay datos de clientes y de RR. HH. **Cuándo usarlo:** Kaspersky: evento de control de dispositivos; eventos de dispositivos externos en Wazuh si están habilitados. **Qué validar:** (1) ¿El dispositivo fue bloqueado o permitido? (2) ¿Qué usuario y qué equipo? (3) ¿Está en la lista aprobada? (4) ¿Qué archivos y volumen se copiaron? (5) ¿El EDR analizó el dispositivo? **Contención permitida a N1:** Pedir que se retire el dispositivo y mantener el bloqueo. Si se copiaron datos confidenciales, escalar a N2 y al responsable. **No debe realizar:** Revisar el contenido del USB personal del usuario, formatear dispositivos, modificar la política. **Escalar si:** Copia de datos sensibles, malware en el dispositivo o reincidencia. **Cierre en GLPI:** Recordar la política; tramitar la autorización del dispositivo con solicitud formal si procede. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-06 · Playbook PB-06 — Phishing reportado	**Objetivo:** Gestionar correos sospechosos reportados por consultores, con foco en robo de credenciales de Microsoft 365 y de la VPN. **Cuándo usarlo:** Reporte de un usuario al buzón dedicado (genera ticket en GLPI) o a soporte. **Qué validar:** (1) ¿Qué solicita el correo (credenciales, pago, adjunto)? (2) ¿El usuario hizo clic, descargó o ingresó datos? (3) ¿Otros destinatarios lo recibieron? (4) Revisar encabezados, dominio del remitente y URL sin abrirla en un equipo de producción. (5) Consultar reputación de URL o hash en servicios públicos. **Contención permitida a N1:** Indicar al usuario que no interactúe; bloquear dominio o URL en el NGFW; solicitar a TI la eliminación del correo en otros buzones; si hubo ingreso de credenciales, cambio inmediato de contraseña y revisión de sesiones. **No debe realizar:** Abrir adjuntos en equipos de producción, responder al remitente, reenviar el correo sin protección. **Escalar si:** Credenciales ingresadas, adjunto ejecutado, campaña a muchos usuarios o suplantación de directivos. **Cierre en GLPI:** Informar al usuario, reforzar concienciación y agregar el dominio a la lista de bloqueo. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-07 · Playbook PB-07 — Escaneo de puertos / reconocimiento	**Objetivo:** Atender reconocimiento contra el puerto de la VPN y otros servicios expuestos. **Cuándo usarlo:** NGFW (IPS) o Wazuh: muchas conexiones denegadas desde una misma IP. **Qué validar:** (1) ¿Origen externo o interno? (2) ¿Qué puertos y servicios fueron objetivo? (3) ¿Se permitió alguna conexión? (4) ¿Hubo intentos posteriores de inicio de sesión desde la misma IP? (5) ¿Es un escáner autorizado? **Contención permitida a N1:** Bloquear temporalmente la IP externa en el NGFW. Si el origen es interno, identificar el equipo y escalar. **No debe realizar:** Escanear de vuelta la IP de origen. **Escalar si:** Origen interno, seguido de explotación o con objetivo en servidor crítico. **Cierre en GLPI:** Confirmar que el firewall mantiene cerrado lo innecesario; registrar la IP como indicador. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-08 · Playbook PB-08 — Cuenta privilegiada nueva o elevación de privilegios	**Objetivo:** Detectar altas de administradores en SRV-C23-AD, SRV-C23-VPN o cambios de membresía de grupos privilegiados. **Cuándo usarlo:** Wazuh: usuario añadido a un grupo de administradores o a sudoers; eventos de creación y de cambio de membresía en Windows; FIM de archivos de cuentas en Linux. **Qué validar:** (1) ¿Existe ticket de solicitud aprobado? (2) ¿Quién realizó la acción y desde dónde? (3) ¿Cuándo ocurrió (fuera de horario)? (4) ¿La cuenta nueva ya se utilizó? (5) ¿Hubo otros cambios al mismo tiempo? **Contención permitida a N1:** Si no está autorizada, solicitar al administrador de TI o a N2 deshabilitar la cuenta y revertir la membresía. El N1 no elimina cuentas privilegiadas. **No debe realizar:** Eliminar o modificar cuentas privilegiadas. **Escalar si:** Siempre que no exista una autorización documentada. **Cierre en GLPI:** Si es autorizada, vincular el ticket; si no, entregar la información a N2. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-09 · Playbook PB-09 — Vulnerabilidad crítica	**Objetivo:** Gestionar CVE críticos o altos detectados por Wazuh en equipos remotos fuera de control y en servidores. **Cuándo usarlo:** Wazuh: detección de vulnerabilidades con CVE críticos o altos en uno o más agentes. **Qué validar:** (1) ¿El software está instalado y en uso? (2) ¿El equipo está expuesto a Internet? (3) ¿Existe parche o mitigación? (4) ¿Hay indicios de explotación en los registros? (5) ¿Cuál es la criticidad del activo en el inventario (Anexo A)? **Contención permitida a N1:** Crear ticket de gestión de vulnerabilidad con responsable y fecha límite; proponer mitigación temporal con aprobación. El N1 no instala parches en producción sin ticket de cambio. **No debe realizar:** Instalar parches o desinstalar software en producción sin ticket de cambio. **Escalar si:** Explotación activa, activo crítico expuesto o sin parche disponible. **Cierre en GLPI:** Confirmar el parche con un nuevo análisis del agente y actualizar el inventario. *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-10 · Playbook PB-10 — Agente de seguridad detenido o desconectado (adicional C23)	**Objetivo:** Atender la detención de un agente (Wazuh o Kaspersky) sin ticket asociado, posible manipulación para evadir controles (escenario 3 de C23), y diferenciar de una simple desconexión por falta de Internet. **Cuándo usarlo:** Wazuh: regla 100320 (agente detenido, derivada de la regla base de «agent stopped»); alerta de agente desconectado superior al umbral definido; Kaspersky: protección deshabilitada. **Qué validar:** (1) ¿Existe ticket de mantenimiento o cambio para ese equipo? (2) ¿Fue una detención del servicio (evento «stopped») o solo falta de conexión (disconnected)? (3) ¿El equipo sigue en línea en la VPN o en el inventario de GLPI? (4) ¿Hubo antes alertas del mismo equipo o usuario (malware, acceso anómalo)? (5) Confirmar con el usuario por canal alterno si apagó el equipo o desactivó la protección. **Contención permitida a N1:** Solicitar al usuario que reinicie el agente o la protección y confirme; si hay sospecha de manipulación, aislar el equipo desde la consola de Kaspersky (si sigue gestionable) y escalar. **No debe realizar:** Acceder remotamente al equipo sin autorización, desinstalar o reinstalar agentes, apagar el equipo del usuario. **Escalar si:** Detención sin ticket y sin explicación; reincidencia; intento de desinstalación; coincide con otra alerta del mismo equipo. **Cierre en GLPI:** Verificar que el agente volvió a reportar; vincular la explicación o el incidente; actualizar la cobertura de agentes (KPI). *(Detalle completo: Anexo F.)*
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-11 · Procedimiento de escalamiento a N2 y matriz de severidad	**Cuándo escalar:** cuando el playbook lo indique, cuando se confirme un verdadero positivo de severidad alta o crítica, o cuando la acción necesaria esté fuera de las permitidas al N1 (aislar servidores, tocar cuentas privilegiadas, restaurar o reinstalar). **Cómo:** (1) cambiar el grupo asignado a «SOC N2» y la prioridad según la matriz; (2) completar la plantilla de escalamiento en el seguimiento: ticket y hora, severidad y SLA, resumen, activos y usuarios, línea de tiempo, evidencias, acciones del N1, hipótesis y confianza, solicitud a N2, contacto; (3) notificar por el canal definido (crítica: llamada al responsable del SOC y a gerencia). **Tiempos (OLA N1 → N2):** N2 reconoce en 30 min si es crítico, 2 h si es alto y el siguiente día hábil si es medio. **Severidad → prioridad GLPI:** Crítica = Mayor (reconocer 15 min / contener 4 h, 24×7) · Alta = Muy alta (30 min / 8 h, 24×7 con guardia) · Media = Media (2 h / 24 h) · Baja = Baja (8 h hábiles / 72 h) · Informativa = Muy baja (1 día hábil / 5 días hábiles).
Categoría · visibilidad	Seguridad › SOC · SOC N1 y N2

KB-12 · Cómo reportar un correo sospechoso	**Si recibes un correo sospechoso:** no hagas clic en enlaces, no abras adjuntos, no respondas y no lo reenvíes a tus compañeros. **Cómo reportarlo:** en Outlook, usa «Reenviar como adjunto» al buzón *reporte-seguridad@talentoremoto.example* (marcador) o crea un ticket en GLPI con la categoría «Seguridad › Phishing» e indica la hora de recepción. No pegues contraseñas en el ticket. **Si ya hiciste clic o escribiste tu contraseña:** avísanos de inmediato por el canal de soporte (llamada o ticket urgente). Cambia tu contraseña desde un dispositivo de confianza y no apagues el equipo hasta que el SOC te lo indique. **Señales de alerta:** urgencia o amenazas, remitente o dominio ligeramente distinto, solicitud de claves o de pagos, enlaces cuyo destino no coincide con el texto, adjuntos inesperados. **Qué pasa después:** el analista revisa el correo, te confirma si es malicioso y, si lo es, lo elimina de otros buzones y bloquea el dominio. Recibirás respuesta dentro del tiempo de servicio de tu ticket.
Categoría · visibilidad	Seguridad › Guías de usuario · Todos (público)

KB-13 · Política de uso de dispositivos USB	**Regla general:** en los equipos de la empresa solo se usan dispositivos USB aprobados. Los datos de clientes y de RR. HH. no se copian a dispositivos personales. **Para pedir autorización:** crea una solicitud en GLPI («Solicitud › Acceso a recursos») indicando el motivo, el tipo de dispositivo y el tiempo requerido. TI valida y registra el dispositivo. **Si el equipo bloquea un USB:** retira el dispositivo y no intentes saltarte el bloqueo; abre una solicitud. Si el dispositivo es de la empresa y no funciona, abre un incidente de TI. **Pérdida o robo:** si pierdes un USB con información de la empresa, reporta de inmediato en GLPI («Seguridad › Fuga de datos / exfiltración»). **Qué monitorea el SOC:** conexión de dispositivos externos y volumen de archivos copiados, con fines de seguridad y conforme a la política de uso aceptable.
Categoría · visibilidad	Seguridad › Guías de usuario · Todos (público)

11. Reportes y tableros

- **Tablero «SOC N1»:** tickets por estado, por categoría, por prioridad, SLA incumplidos y tickets sin asignar.
- **Búsquedas guardadas:** tickets de la categoría Seguridad (una por subcategoría); tickets sin asignar; tickets por vencer; tickets escalados a N2.
- **Exportación a CSV** para los KPIs del Manual SOC: MTTA = promedio del tiempo de toma en cuenta; MTTR = promedio del tiempo de resolución; tasa de falsos positivos = tickets cerrados como falso positivo ÷ total

cerrados × 100 (use un campo o una solución estándar «Falso positivo» para poder contarlos); cumplimiento de SLA = tickets dentro de SLA ÷ total × 100. Verifique los nombres exactos de las columnas en la exportación de su versión.

12. Diseño corporativo

Elemento	Detalle
Logo y favicon	Archivos propios y ficticios entregados: logo_TalentoRemoto_ficticio.png (512×512) y favicon_TalentoRemoto_ficticio.png (64×64). No se usan logos de empresas reales.
Colores	Azul marino #1F3A5F (principal) y verde azulado #2A7F8E (acento).
Texto de bienvenida	«Bienvenido al portal de soporte y seguridad de TalentoRemoto Staffing TI S.A.S.. El uso de los sistemas está sujeto a la política de uso aceptable. Para reportar un incidente de seguridad escriba a soporte@talentoremoto.example o cree un ticket.»
Dónde se configura	Logo y texto de bienvenida: Configurar → General → Personalización (pantalla de inicio de sesión) o CSS personalizado en la entidad raíz; confirmar la ruta exacta en la versión instalada y anotarla junto a la captura F04_18.

13. Respaldos y prueba de restauración

- Programar con cron: volcado diario de la BD (mariadb-dump con --single-transaction y gzip), copia diaria de los directorios files y config, y borrado de copias con más de 14 días (guía 4.7). Copiar los respaldos fuera del servidor.
- Tomar una instantánea del servidor después de la configuración final.
- **Prueba de restauración (documentar con capturas):** (1) anotar el número de tickets actual; (2) crear un ticket de prueba y borrarlo o restaurar sobre una BD de prueba; (3) restaurar el volcado en una base de datos nueva o en una VM de prueba; (4) comprobar el número de tickets y el acceso; (5) registrar fecha, tiempo empleado y resultado.
- Evidencia: F04_13_respaldo, F04_14_restauracion y el resultado de la prueba (fecha, duración y tickets verificados): [registrar tras ejecutarla].

14. Lista de verificación de puesta en marcha y evidencias

Verificación	Cumple	Captura / evidencia
HTTPS activo y certificado válido; sin cuentas por defecto	☐	F04_05, F04_07
Cron de GLPI funcionando	☐	F04_08
Entidad raíz y subentidades; 10 usuarios ficticios con perfiles y grupos	☐	F04_10, F04_19
Categorías, SLA/OLA, plantilla y reglas de negocio activos	☐	F04_11, F04_20
Notificación por correo probada (captura del mensaje recibido)	☐	F04_12
Inventario: equipos del laboratorio con GLPI Agent y equipos de red registrados	☐	F04_15
Base de conocimiento con al menos 12 artículos	☐	F04_16
6 tickets de ejemplo con la plantilla (uno por tipo de alerta) y un tablero de reportes	☐	F04_17, F04_21
Respaldo realizado y restauración probada	☐	F04_13, F04_14
Diseño corporativo aplicado	☐	F04_18

Errores comunes a evitar: cuentas por defecto o contraseñas débiles en una instancia expuesta; olvidar el cron (no se envían correos ni se calculan SLA); apuntar Apache a la raíz de GLPI y no a *public*; puertos 25/465 bloqueados por el proveedor (usar 587 con contraseña de aplicación); zona horaria o tablas de zonas horarias sin configurar; puerto 22 abierto a todo Internet; SLA distintos a los de la Fase 6.
Documento elaborado por Angel David Rey — Ingeniería de Sistemas, Unidades Tecnológicas de Santander — 22 de octubre de 2026. Las capturas de evidencia deben mostrar fecha, hora, usuario y hostname con las iniciales ADR / C23.